

Integridad del Ciclo de Vida y los Datos



Envenenamiento de datos

Data Poisoning

El envenenamiento de datos ocurre cuando un atacante introduce, de forma deliberada, información maliciosa o manipulada en el conjunto de datos usado para entrenar o ajustar un modelo de IA. A diferencia de un ataque "en vivo", este contamina la fuente desde la que el modelo aprende, por lo que puede pasar desapercibido durante meses.



Tipos de Envenenamientos y un Caso Real

Ataques dirigidos



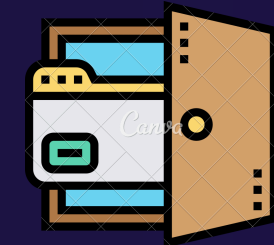
Buscan que el modelo falle solo ante casos muy específicos (ej. no detectar un tipo particular de malware).

Ataques no dirigidos



Degradan el rendimiento general del modelo, sin un objetivo puntual.

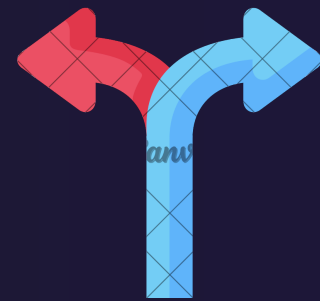
Ataques de puerta trasera



El modelo se comporta con normalidad, excepto cuando recibe una señal oculta que el atacante conoce convirtiéndolo en un "agente durmiente".

Tipos de Envenenamientos y un Caso Real

Envenenamiento por vista dividida (split-view) o por adelantamiento (frontrunning)



Técnicas que aprovechan cómo se recolectan o actualizan los datos de entrenamiento con el tiempo, insertando contenido dañino durante ese proceso sin ser detectado (por ejemplo, alterando una fuente de datos justo antes de que el sistema la recolecte).



Investigadores modificaron directamente los parámetros de un modelo ya entrenado y lo publicaron en un repositorio público simulando que era legítimo, demostrando lo fácil que es distribuir un modelo "envenenado" sin que el usuario lo note.

El Riesgo en un Sistema SOAR Real

En cualquier sistema SOAR (Security Orchestration, Automation and Response) que use un modelo de IA para decidir automáticamente cómo responder a una alerta, ese modelo es el que decide si una alerta se convierte en una acción automática: bloquear una IP, aislar un host, etc.

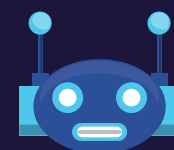
Si el modelo fue entrenado con datos envenenados, el sistema puede terminar:



Ignorando ataques reales en curso.



Ejecutando acciones dañinas automáticamente contra infraestructura propia.



Operando sin la supervisión adecuada.

Robo y Extracción de Modelos

Ocurre cuando un atacante consulta repetidamente un modelo expuesto a través de una API pública o un servicio en la nube (MLaaS) y usa las respuestas obtenidas para reconstruir una copia funcional del modelo original, sin acceder directamente a su código.

Riesgos principales



Pérdida de propiedad intelectual (años de investigación e inversión)



Filtración indirecta de datos de entrenamiento (ataques de inversión o de inferencia de pertenencia)



Elusión de controles: si el atacante posee una copia del modelo de detección, puede probar en privado qué ataques logran evadirlo antes de lanzarlos contra el sistema real



Caso Proof Pudding (CVE-2019-20634)

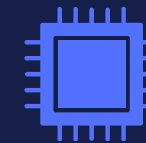
La divulgación de datos de entrenamiento facilitó la extracción e inversión de un modelo, permitiendo evadir filtros de seguridad de correo basados en aprendizaje automático.

Como se Protege el Dato y el Modelo



Para proteger los DATOS (contra envenenamiento):

- **Trazabilidad de datos:** control de versiones de datasets (data provenance).
- **Sandboxing:** limitar el acceso del modelo a fuentes no verificadas.
- Detección de anomalías previas al uso.
- Entrenamiento adversarial y "red team".
- Monitoreo de la pérdida de entrenamiento.



Para proteger el MODELO (contra robo/extracción):

- **Rate limiting:** Limitar frecuencia de consultas a la API.
- **Watermarking:** Marcas de agua sobre salidas del modelo.
- **RBAC:** Control de acceso robusto e inventario.
- Restringir información devuelta (ocultar logits).
- Privacidad diferencial durante entrenamiento.

Consolidando la Respuesta y la Gobernanza

De las anomalías a la evidencia: ¿Qué estándares garantizan que un sistema de IA es auditable y confiable?

IA Explicable (XAI) para Análisis Forense

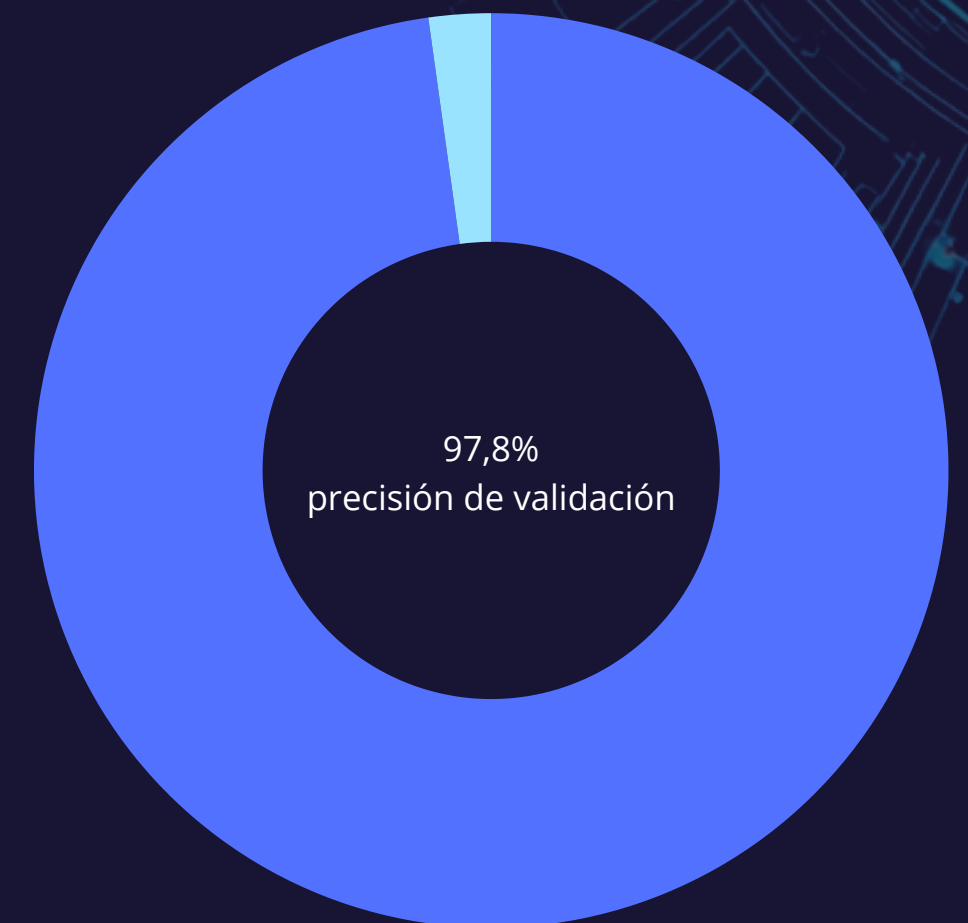
Muchos modelos de detección funcionan como “cajas negras”: producen una alerta pero no explican por qué. Un analista del SOC necesita entender la razón antes de aprobar una acción automática, y una investigación forense exige evidencia comprensible.

SHAP y LIME identifican qué características de un evento (puerto, volumen de tráfico, frecuencia de peticiones) influyeron más en la decisión del modelo

Beneficios para Secops

- **Reduce falsos positivos:** el analista puede validar si la alerta tiene sentido antes de escalarla.
- **Acelera la respuesta:** muestra de inmediato qué variables dispararon la alerta.
- **Documentación auditable:** requisitos de marcos como el NIST AI RMF.
- **Mejora continua del modelo:** revela sesgos o patrones inesperados.

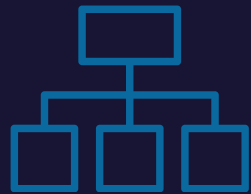
Dato respaldo por estudio reciente



XGBoost + SHAP sobre el dataset UNSW-NB15, superando a TabNet en estabilidad y coherencia de las explicaciones.

Integración con SIEM y SOAR

La IA Explicable debe conectarse con el Flujo de Defensa Institucional.



Flujo Operativo

El modelo detecta la amenaza, la capa XAI genera la explicación en el SIEM, y el SOAR automatiza la respuesta o escala el incidente.



Gobernanza

Se debe definir previamente qué nivel de riesgo permite automatización total y cuál exige revisión humana ("human-in-the-loop").



Evidencia y Feedback

Toda decisión debe registrarse para auditorías. Los analistas corrigen los falsos positivos para reentrenar el modelo de IA.

NIST AI Risk Management Framework

Publicado en 2023 (EE. UU.), es el marco voluntario estándar para incorporar confiabilidad en el ciclo de vida de la IA. Sus 4 funciones:

Gobernar: Políticas, cultura organizacional y responsables claros.

Mapear: Identificar el contexto de uso e impactos potenciales.

Medir: Pruebas continuas de riesgo y rendimiento técnico.

Gestionar: Asignar recursos, mitigar y planificar contingencias.



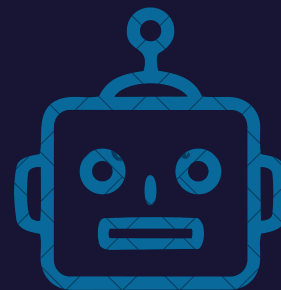
Estándar OWASP Top 10 para LLMs (2025)

Los riesgos críticos más relevantes para un ecosistema con automatización.



LLM04: Envenenamiento

Manipulación maliciosa de la fuente de datos o del modelo. Conecta directamente con las amenazas abordadas en el Tema 2.



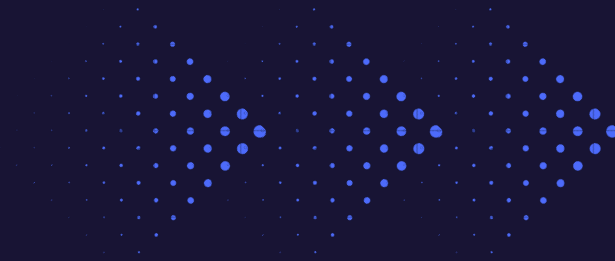
LLM06: Agencia Excesiva

Otorgar demasiada autonomía a un flujo automatizado (como un SOAR) sin la debida supervisión, permisos o validación humana.



LLM10: Consumo Abusivo

Ataques de "Denial of Wallet" que agotan recursos financieros en APIs o extraen datos del modelo mediante abuso sistemático.



Seguridad Continua: Conclusión



La seguridad de la IA no es un producto que se instala una vez, sino un proceso continuo de gobernanza, medición y mejora

